

一张图片之后， 权限走了多远？

OpenAI 论坛事件中的三道边界

图片解析 → 登录身份 → 连接器权限

依据 Hacktron 研究报告；结合公开安全公告与防御分析

先看发生了什么

研究者报告

论坛漏洞 + SSO 配置问题

形成跨服务的账户访问路径

演示的影响

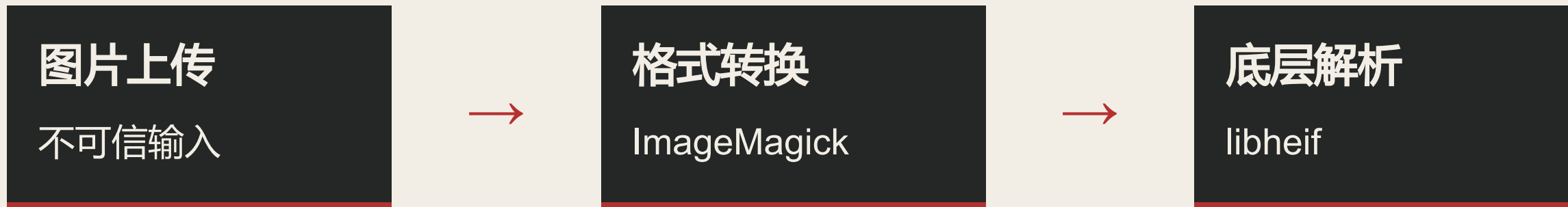
经员工 Codex 账户
创建内部仓库测试 PR

证据的边界

作者称未读取内部代码
潜在访问 ≠ 已证实泄露

来源：Hacktron 《Hacking OpenAI》；事件叙述为研究者披露

第一道边界：文件变成计算



风险藏在“自动处理”里

解析器漏洞可能让数据处理变成代码执行

Discourse 公告: GHSA-vhm9-85gw-x335 · CVE-2026-32882

第二道边界：登录不是万能钥匙

以下为防御性类比，并非漏洞协议细节

访客证

允许进入论坛

只服务于这个应用

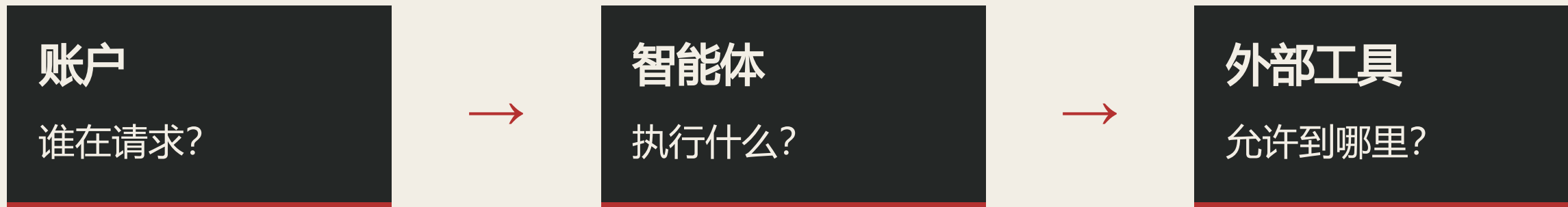
机房钥匙

访问另一套系统

必须独立核验权限

共享身份，不应抹去应用之间的权限边界。

第三道边界：连接器扩大影响



防御分析：影响范围取决于已经授予的权限

按仓库授权 · 区分读写 · 可撤销 · 可审计

修复要落到正在运行的环境

01

更新依赖

核对安全公告
与发行版补丁

02

重建部署

替换旧镜像
确认运行版本

03

隔离处理

限制格式与资源
缩小进程权限

Discourse 公告要求重建，并增加图片处理沙箱。

来源：Discourse 安全公告；ImageMagick 安全策略文档

AI 改变了成本，也改变了节奏

研究者观察

模型帮助推进漏洞利用开发

仍有专业人员提供方向与判断

不能据此推断

所有目标都同样容易
或所有步骤都能自主完成

值得提前准备

缩短补丁部署周期
关注解析器异常与权限使用

把每一次跨界， 都当成一次授权。

输入要隔离，身份要限域，工具要限权。

从图片处理链开始，检查通向关键资源的整条路径。

原文：hacktron.ai/blog/hacking-openai

补充：Discourse 安全公告 · ImageMagick 安全策略